

Design Document using SA/SD Methodology

for

Website Vulnerability Scanner

Prepared by

Deepthi K (241IT021)
Jasmine (241IT051)
Sacheth Koushal (241IT058)

Department of Information Technology
National Institute of Technology Karnataka, Surathkal

September 2025

Contents

1	Data Flow Diagram (DFD) Model	2
1.1	Level 0 DFD	2
1.1.1	Context Diagram	2
1.2	Level 1 DFD	2
1.2.1	Top-Level Functional Decomposition	2
1.3	Level 2 DFDs	4
1.3.1	0.1 User Authentication & Access Control	4
1.3.2	0.2 Target Management & Authorisation	4
1.3.3	0.3 Scan Configuration & Execution	6
1.3.4	0.4 Discovery (Crawling)	6
1.3.5	0.5 Vulnerability Detection	7
1.3.6	0.6 Findings Management	7
1.3.7	0.7 Reporting & Export	8
1.3.8	0.8 Safety, Auditing & Administration	8
2	Core Modules	9
2.1	0.1 User Authentication & Access Control	9
2.2	0.2 Target Management & Authorisation	9
2.3	0.3 Scan Configuration & Execution	9
2.4	0.4 Discovery (Crawling)	9
2.5	0.5 Vulnerability Detection	9
2.6	0.6 Findings Management	9
2.7	0.7 Reporting & Export	9
2.8	0.8 Safety, Auditing & Administration	10
3	Structure Charts	10
3.1	Level 1 Structure Chart	10
3.1.1	Module Decomposition	10

1 Data Flow Diagram (DFD) Model

1.1 Level 0 DFD

1.1.1 Context Diagram

Figure 1 illustrates the Level 0 Context Diagram for the Website Vulnerability Scanner system. It defines the primary system boundary for Process 0 and models all inbound/outbound interaction channels with key external entities including the WVS User, System Administrator, Target Website, Public DNS Resolvers, SMTP Relay, and OSV/EPSS Advisory APIs.

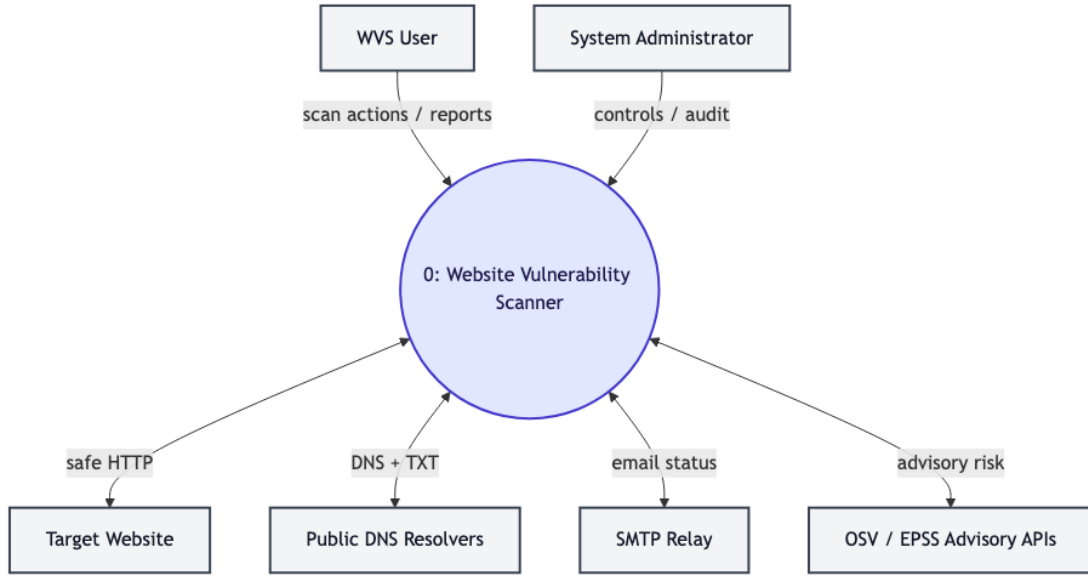


Figure 1: Level 0 Context Diagram

1.2 Level 1 DFD

1.2.1 Top-Level Functional Decomposition

Figure 2 depicts the Level 1 DFD, decomposing Process 0 into 8 primary functional modules (0.1 through 0.8). It displays the primary scanning pipeline from initial user request through scope validation, discovery crawling, vulnerability detection, findings management, and report generation, alongside centralized Scope Guard enforcement (0.8) and third-party integrations.

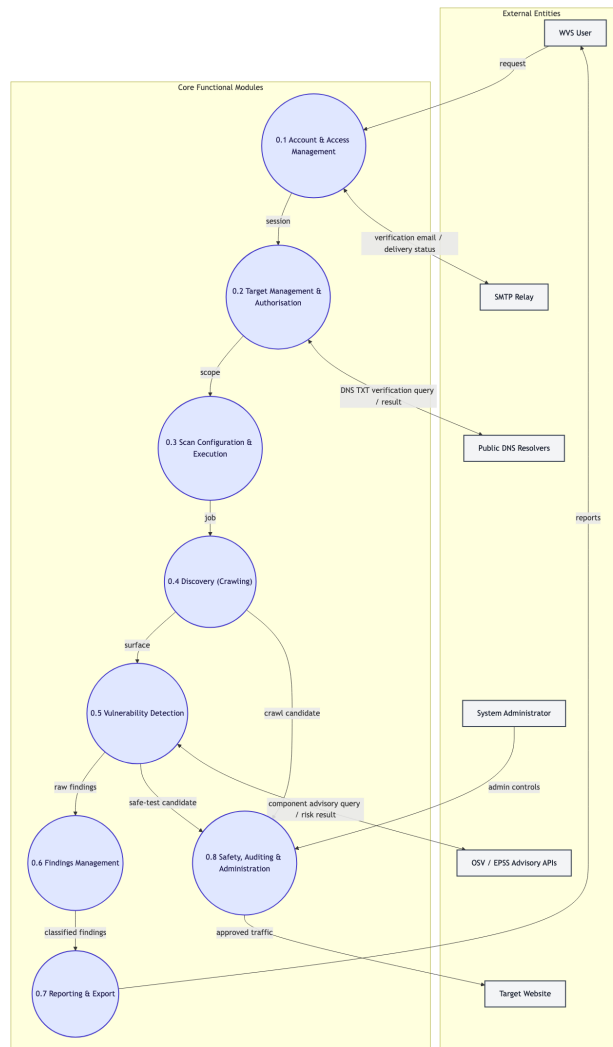


Figure 2: Level 1 DFD with 8 functional groups

1.3 Level 2 DFDs

1.3.1 0.1 User Authentication & Access Control

Decomposes Process 0.1 into credential validation, session token issuance, and login audit logging. Process 1.1 validates user credentials against Data Store D1, Process 1.2 issues session tokens and verifies email deliverability via SMTP Relay, and Process 1.3 records authentication audits.

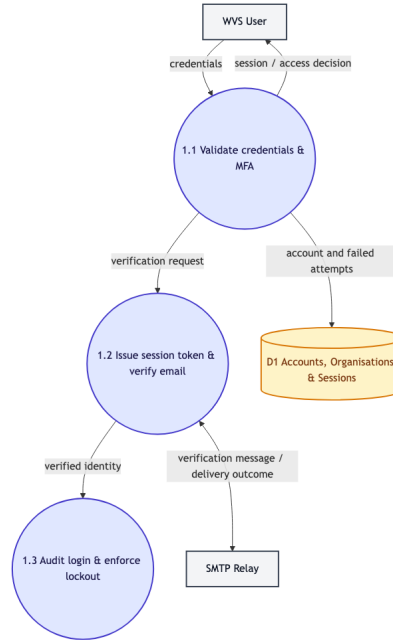


Figure 3: Level 2 DFD for 0.1 User Authentication & Access Control

1.3.2 0.2 Target Management & Authorisation

Decomposes Process 0.2 into target registration, verification token generation, and DNS/well-known proof validation. Process 2.1 registers target definitions in D2, Process 2.2 generates ownership tokens verified against Public DNS, and Process 2.3 checks well-known path tokens on the Target Website.

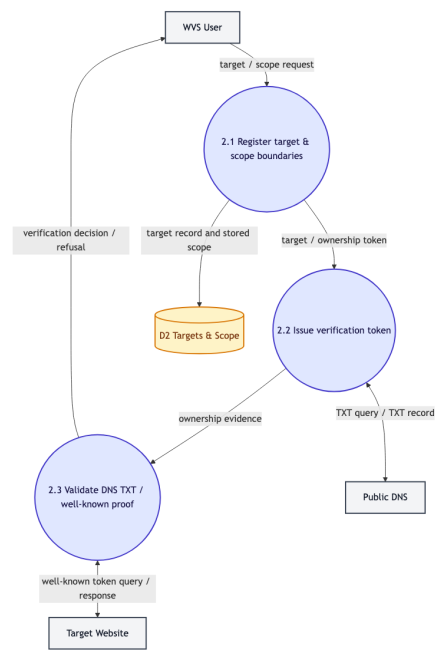


Figure 4: Level 2 DFD for 0.2 Target Management & Authorisation

1.3.3 0.3 Scan Configuration & Execution

Decomposes Process 0.3 into scan profile validation, job scheduling, and lifecycle execution. Process 3.1 verifies user scope and quotas against D2, Process 3.2 queues scan jobs in D3, and Process 3.3 executes the scan lifecycle while writing reproducibility records to D4.

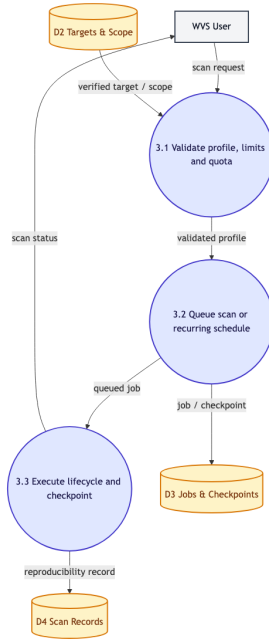


Figure 5: Level 2 DFD for 0.3 Scan Configuration & Execution

1.3.4 0.4 Discovery (Crawling)

Decomposes Process 0.4 into scope loading, link/form discovery, and JS rendering deduplication. Process 4.1 loads ceilings from D2, Process 4.2 dispatches crawl candidates to Process 0.8 Scope Guard, and Process 4.3 records page inventory in D4 upon receiving HTTP responses from the Target Website.

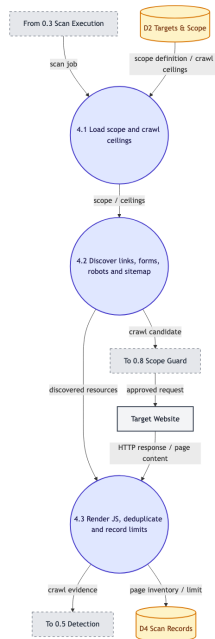


Figure 6: Level 2 DFD for 0.4 Discovery (Crawling)

1.3.5 0.5 Vulnerability Detection

Decomposes Process 0.5 into passive header checking, safe active test preparation, and advisory version enrichment. Process 5.1 runs passive analysis, Process 5.2 routes active test payloads through Process 0.8 Scope Guard, and Process 5.3 queries OSV/EPSS APIs and stores evidence in D5.

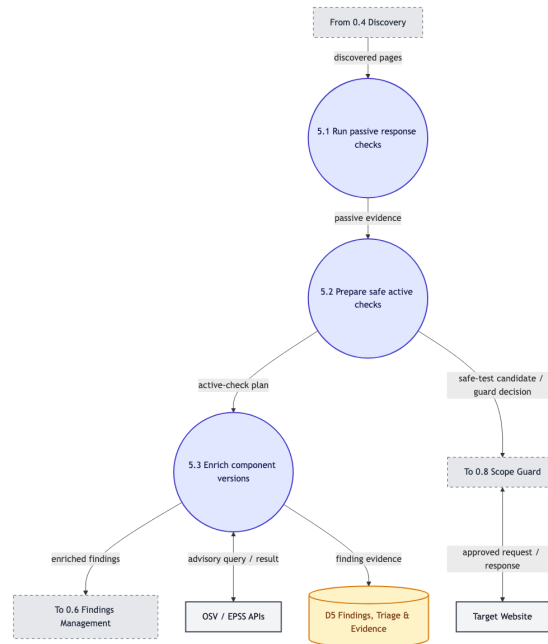


Figure 7: Level 2 DFD for 0.5 Vulnerability Detection

1.3.6 0.6 Findings Management

Decomposes Process 0.6 into normalisation/redaction, historical scan comparison, and triage filtering. Process 6.1 ingests raw findings, Process 6.2 compares historical evidence stored in D5, and Process 6.3 applies user triage filters and severity classification.

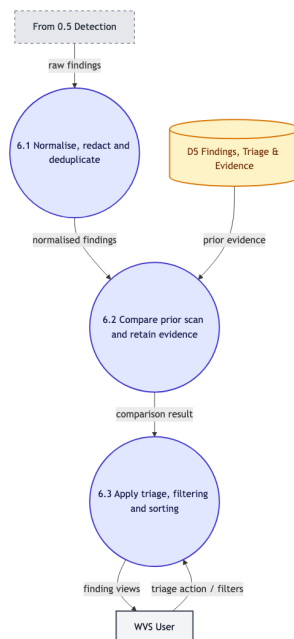


Figure 8: Level 2 DFD for 0.6 Findings Management

1.3.7 0.7 Reporting & Export

Decomposes Process 0.7 into completed scan selection, report template assembly, and export dispatch. Process 7.1 retrieves scan metadata from D4, Process 7.2 compiles finding evidence from D5, and Process 7.3 generates export files (PDF/CSV) and triggers SMTP notifications.

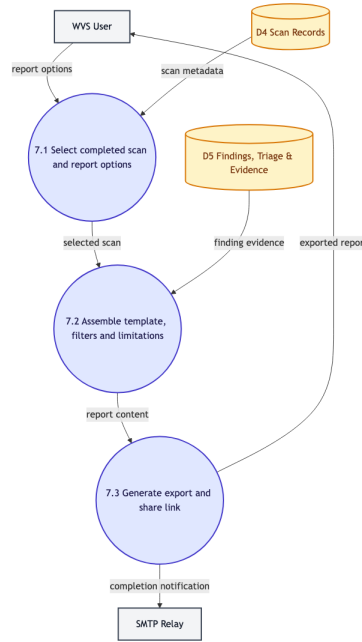


Figure 9: Level 2 DFD for 0.7 Reporting & Export

1.3.8 0.8 Safety, Auditing & Administration

Decomposes Process 0.8 into scope/blocklist verification, IP re-resolution & rate limiting, and request dispatch. Process 8.1 evaluates requests against D2 policies, Process 8.2 performs fresh DNS checks to prevent SSRF, and Process 8.3 logs dispatches to D6 Append-only Audit Ledger.

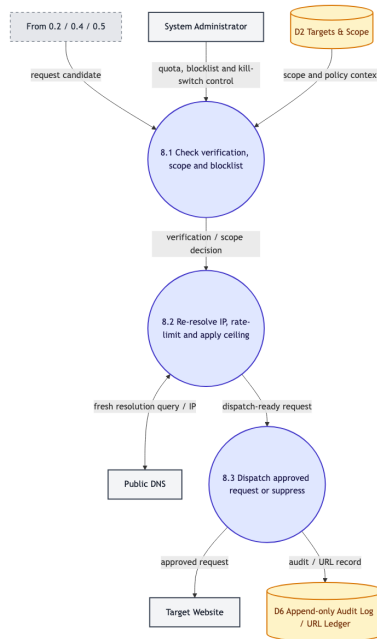


Figure 10: Level 2 DFD for 0.8 Safety, Auditing & Administration

2 Core Modules

This section describes the core functional modules of the Website Vulnerability Scanner. Each module manages a distinct phase of the scanning lifecycle.

2.1 0.1 User Authentication & Access Control

Handles user authentication, organisation onboarding, session management, and multi-factor verification.

- **Functions:** Register User, Validate Credentials & MFA, Issue Session Token (JWT), Audit Login & Enforce Lockout.

2.2 0.2 Target Management & Authorisation

Manages domain registration, scope definitions, ownership verification tokens, and DNS/well-known target validation.

- **Functions:** Register Target & Scope, Issue Verification Token, Validate DNS TXT / Well-Known Proof, Store Scope Rules.

2.3 0.3 Scan Configuration & Execution

Validates scan profile settings, checks user quotas, queues execution jobs, and manages lifecycle execution checkpoints.

- **Functions:** Validate Profile & Quota, Queue Scan Job / Schedule, Execute Lifecycle & Checkpoint, Record Scan Reproducibility.

2.4 0.4 Discovery (Crawling)

Extracts attack surface elements including links, forms, API endpoints, and dynamic JS content while abiding by crawl ceilings.

- **Functions:** Load Scope & Ceilings, Discover Links & Sitemap, Render JS & Deduplicate, Dispatch Candidates to Scope Guard.

2.5 0.5 Vulnerability Detection

Performs non-destructive vulnerability checks, passive header analysis, active payload testing via Scope Guard, and advisory database lookup.

- **Functions:** Run Passive Response Checks, Prepare Safe Active Checks, Enrich Component Versions via OSV/EPSS APIs.

2.6 0.6 Findings Management

Normalises raw scan evidence, redacts sensitive tokens, correlates findings against prior scan runs, and applies triage filters.

- **Functions:** Normalise & Redact Findings, Compare Prior Scan Evidence, Apply Triage, Filtering & Severity Sorting.

2.7 0.7 Reporting & Export

Assembles executive and technical report documents, formats exports (PDF/CSV), and dispatches completion notifications.

- **Functions:** Select Completed Scan, Assemble Report Template & Evidence, Generate Export / Share Link, Send SMTP Notification.

2.8 0.8 Safety, Auditing & Administration

Enforces safety invariants, validates target scope, re-resolves DNS to prevent TOCTOU/SSRF attacks, applies rate limits, and maintains an append-only URL ledger.

- **Functions:** Check Verification & Scope Blocklist, Re-resolve IP & Rate-Limit, Dispatch Approved Request, Append Audit Log.

3 Structure Charts

3.1 Level 1 Structure Chart

3.1.1 Module Decomposition

The system module hierarchy follows a structured top-down functional decomposition, decoupling user interface and management services from the core crawling engine, detection modules, and centralized Scope Guard safety layer. Figure 11 illustrates the Level 1 Structure Chart of the System.

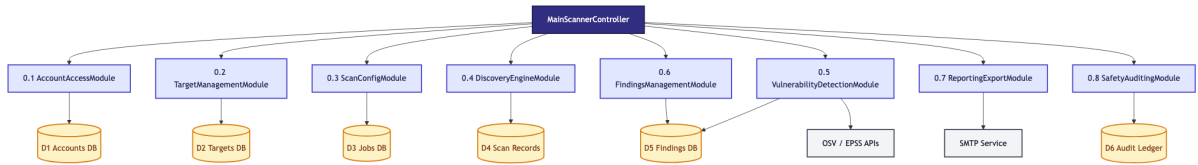


Figure 11: Level 1 Structure Chart of the System